

Relatório do trabalho de grupo

Plano de segurança inicial para serviço web publicado

1. Identificação do grupo

Grupo: X

Elemento: Edmilson Landim

Papéis assumidos: Edmilson Landim — responsável por todas as tarefas (preparação do ambiente, execução técnica, documentação e validação).

2. Serviço analisado

Cenário escolhido: A — página HTML com Nginx.

Característica	Detalhe
Serviço	Nginx 1.18.0 (Ubuntu)
Porta / protocolo	TCP 80 / HTTP
Diretório de publicação	/var/www/html/topico-03/
Componentes envolvidos	Ubuntu 22.04.3 LTS (WSL2), Nginx, ficheiros estáticos HTML5/CSS3
Dependências principais	Nenhuma dependência de runtime (sem PHP nem base de dados) — conteúdo estático puro

O serviço publicado no Tópico 3 é uma página de portefólio técnico estática, sem lógica de servidor nem base de dados associada, o que reduz à partida a superfície de ataque em comparação com um serviço dinâmico (ex.: WordPress).

3. Superfície de ataque

Elemento exposto	Risco	Necessário?	Medida proposta
SSH	Alvo comum de força bruta e scanning automático	Não (sem servidor SSH instalado)	Manter desinstalado; se instalado no futuro, usar só chave e desativar login root
HTTP	Tráfego em texto simples (sem cifra)	Sim — é o serviço a expor	Manter aberto (porta 80); sem alternativa nesta fase
HTTPS	Sem HTTPS, dados futuros circulariam sem cifra	Ainda não configurado	Não abrir a porta 443 enquanto não houver certificado TLS válido
Base de dados	Exposição direta permitiria acesso não autorizado	Não aplicável (site estático)	Manter porta 3306 sempre fechada; nunca expor BD à internet
Diretório web	Permissões incorretas podem expor/alterar ficheiros	Sim, com permissões controladas	Ficheiros 644, dono www-data, nunca 777
WordPress admin	Não aplicável a este cenário	—	—

4. Regras de firewall propostas

Serviço	Porta	Decisão	Justificação
SSH	22	Fechada	Sem servidor SSH instalado; abrir sem necessidade real aumenta a superfície de ataque
HTTP	80	Aberta	Único serviço que precisa de estar acessível para cumprir o objetivo de publicação
HTTPS	443	Fechada (por agora)	Sem certificado TLS configurado; abrir sem o serviço correspondente não traria benefício

MariaDB/MySQL	3306	Fechada	Não existe base de dados neste cenário; sem motivo para expor
---------------	------	---------	---

Política aplicada: **negar todo o tráfego de entrada por omissão** (UFW, *default deny incoming*), com exceção explícita apenas para a porta 80/tcp (IPv4 e IPv6) — o mínimo estritamente necessário.

5. Medidas de hardening inicial

- 1 **Atualizar pacotes** — `apt update && apt upgrade`, para aplicar correções de segurança pendentes ao sistema e ao Nginx.
- 2 **Ocultar a versão do servidor** — desativar o cabeçalho Server detalhado do Nginx (`server_tokens off;`), reduzindo a informação exposta.
- 3 **Rever permissões em /var/www/html** — confirmar 644 e propriedade www-data, nunca 777.
- 4 **Remover a página de boas-vindas por omissão do Nginx**, que sinaliza uma instalação por corrigir.
- 5 **Evitar o uso direto de root** — os processos worker do Nginx já correm como www-data, não root.
- 6 **Rever contas de utilizador do sistema** (`/etc/passwd`), confirmando ausência de contas de teste ou inativas.
- 7 **Documentar todas as alterações** feitas ao servidor, para facilitar auditoria e manutenção futura.

6. Plano de validação

Validação	Como fazer	Resultado esperado	Evidência
Estado da firewall	<code>sudo ufw status verbose</code>	active, deny incoming por omissão, só 80/tcp ALLOW IN	evidencias/firewall-de pois.txt
Serviço web acessível	<code>curl -I http://localhost/topico-03/index.html</code>	HTTP/1.1 200 OK	evidencias/curl-validacao.txt
SSH disponível	<code>systemctl status ssh</code>	Unit ssh.service could not be found (ausência intencional)	evidencias/ssh-verificacao.txt
Portas desnecessárias fechadas	<code>sudo ufw status verbose + sudo ss -t -n -P grep LISTEN</code>	Só porta 80 (Nginx) e 53/loopback (DNS) em escuta	evidencias/portas-antes.txt

7. Link do repositório GitHub

<https://github.com/edmilsonLandim/linux-seguranca-cloud/tree/main/topico-04/trabalho-grupo>

8. Conclusão

O cenário analisado (página HTML estática servida por Nginx) tem, por natureza, uma superfície de ataque reduzida: sem base de dados, sem PHP e sem autenticação de utilizadores finais. Ainda assim, a aplicação de uma política de firewall restritiva (negar por omissão, só abrir o estritamente necessário) e de medidas básicas de hardening (atualizações, permissões corretas, redução da informação exposta) reforça essa vantagem inicial, em vez de a desperdiçar por configuração deixada ao acaso. O plano acima foi validado com evidências reais recolhidas no próprio ambiente do grupo, não apenas proposto em teoria.